

Glossary: Introduction to Information Security and Compliance

Welcome! This alphabetized glossary contains many of the terms you'll find within this course. This comprehensive glossary also includes additional industry-recognized terms not used in course videos. These terms are important for you to recognize when working in the industry, participating in user groups, and participating in other certificate programs.

Term	Definition
Acceptable Use Policy (AUP)	Sets standards for how technology resources should be used in an organization.
Access control standard	A framework for defining who can access specific resources in a computing environment.
Acknowledgment	Involves recognizing or admitting the truth or existence of something.
Advanced Encryption Standard (AES)	An encryption standard for stored data.
Asset lifecycle tracking	Helps monitor all stages of an asset's lifespan from acquisition through disposal.
Asset tagging	A method for easy asset monitoring, you can assign each asset a unique identifier, such as a barcode.
Attestation	Witnessing and verifying that something is true or that a document is authentic.
Automation	Creating and applying technology, systems, or software to perform tasks with minimal human intervention.
Business continuity plan	Describes how to make sure that critical operations can carry on both during and after an interruption or disaster.
Change management procedures	Guide the implementation of changes within an organization.
Chemical destruction	A device destruction method you can use to dissolve memory chips and other data storage components by employing specialized chemical processes.
Compliance	Following laws, regulations, standards, and internal policies that apply to the organization.
CyberGRC	Manages IT and cybersecurity risks.
Detect component	A CSF component in which you actively identify and seek potential cyberattacks.
Degaussing	A device destruction method you can use to erase the magnetic media by applying a powerful magnetic field.
Disaster recovery plans	Outline actions to recover and restore IT infrastructure and operations following a disaster.
Due diligence	Involves thoroughly investigating and validating an organization's security posture and threats before making strategic decisions.
Electromagnetic destruction	A device destruction method, you can use electromagnetic pulses to permanently erase data on electronic devices.
General Data Protection Regulation (GDPR)	A regulation in the European Union that mandates strict guidelines for data protection and privacy.
GDPR Governance, Risk, and Compliance (GRC)	A structured framework that meets regulatory requirements efficiently manages risk and matches IT business objectives.
Governance	Setting up policies, procedures, and guidelines to help an organization make decisions and operate smoothly.
Govern component	A core CSF component in which you create and verify cybersecurity policies.
Guidelines	Provide recommended best practices that help organizations accomplish their compliance and risk management objectives effectively.
IBM OpenPages with Watson	Uses Watson AI to provide insights into risk and compliance management, offering targeted solutions across various domains.
IBM FIRST Risk Case Studies	Offers a comprehensive database of external risk case studies, allowing for analyzing risk events within the financial services sector.
Identify component	A CSF component where you understand the cybersecurity risks and recognize the assets that the organization possesses, like systems and data, and the threats connected to them.
Incident response plans	Outline effective management and response to security incidents or breaches.

Incineration	A device destruction method where you can use high temperatures to melt down electronics, ensuring no data recovery is possible.
Information security policies	Outline ways to protect against breaches and unauthorized access to sensitive data.
Inventory management software	A specialized software that helps you record, update, and maintain the asset database, providing a centralized platform for tracking asset information.
MetricStream	Offers a range of GRC solutions that help organizations improve their risk, compliance, and governance decision-making.
Multifactor authentication (MFA)	A standardized solution for authentication across all access points.
NIST Cybersecurity Framework (CSF 2.0)	Outlines methods for managing cybersecurity risks in an organization.
Onboarding protocols	The standardized process of integrating a new employee into an organization.
Offboarding protocols	The standardized process of managing the departure of an employee from the company.
Orchestration	Involves coordinating automated tasks and workflows across various systems and services.
Policies	Specify what is permissible and what is not permissible within the parameters of organizational activity.
Protection component	A CSF component, in which you use security measures to mitigate cyber threats and safeguard the organizational assets to reduce or eliminate cyberattacks.
Reconciliation process	A process you use to compare and reconcile recorded asset data against physical inventory to identify discrepancies and update records as necessary.
Recovery component	A CSF component, in which you restore operations and assets impacted by a cyberattack.
Response component	A CSF component, in which you prepare a response to discovered cybersecurity incidents.
Risks	Include financial uncertainties, cybersecurity threats, operational issues, and not following regulations.
Risk management	Identifying, evaluating, and addressing potential threats that could harm the organization.
Role-Based Access Control (RBAC)	An automation used to ensure users have essential permissions.
RSA Archer Suite	Provides several software solutions that create a comprehensive framework for managing risks, demonstrating compliance, and automating business processes.
Sanctions	Measures taken by regulatory bodies or governments to enforce compliance.
Secure Sockets Layer/Transport Layer Security (SSL/TLS)	A security layer recommended by encryption standards for in-transit data.
Single sign-on (SSO)	A user authentication process that allows a user to access multiple applications or systems with one set of credentials.
Standards	Established norms or requirements in technical systems that ensure quality, safety, and efficiency.
Tier 1: Partial	At this CSF tier level, an organization uses impromptu and occasionally reactive methods in its cybersecurity procedures.
Tier 2: Risk-Informed	At this CSF tier level, organizations exhibit risk awareness and apply risk-informed cybersecurity procedures, although not throughout the organization.
Tier 3: Repeatable	At this CSF tier level, organizations create and regularly implement cybersecurity procedures.
Tier 4: Adaptive	At this CSF tier level, organizations continuously modify their cybersecurity measures considering ongoing and past cybersecurity activities.



Skills Network